

Checklist M1 · API nền + Auth

Dự án: Da Nang Connect — Giai đoạn 1 (MVP) · **Trạng thái chụp:** 19/09/2026 · **Ngày chốt:** 02/10/2026

Bản sửa được: docs/checklists/checklist-milestone-M0-M6.xlsx (mỗi phase một sheet, cột Trạng thái có danh sách chọn, sheet Tổng quan tự tính lại).

1. Cách đọc

Trạng thái:

-  **Xong:** đã làm và có bằng chứng (test, ảnh, link).
-  **Một phần:** đã có code hoặc cấu hình nhưng còn thiếu phần ghi ở cột Ghi chú.
-  **Chưa làm:** chưa bắt đầu. Đây là mặc định cho các mục M2-M6 chưa được kiểm tra chi tiết.
-  **Bị chặn:** phải chờ việc khác xong (ghi ở cột Ghi chú).
-  **Cần chốt:** cần quyết định của Founder, Product Owner, Tech Lead, BA hoặc luật sư trước khi làm.
-  **Chưa xác nhận:** việc ngoài repo (pháp lý, tài khoản, vận hành) chưa có bằng chứng; người phụ trách tự xác nhận.

Nhóm việc trong mỗi phase: Việc chặn & cần chốt → Story → DoD bổ sung → Nghiệm thu → Demo → Việc ngoài SP → Bổ sung từ mockup.

Nguồn trạng thái: M0-M1 lấy từ đợt kiểm tra code chỉ đọc ngày 18/09/2026 (có đối chứng độc lập). Các mục "Một phần" của M2-M3 lấy từ ghi chú phiên làm việc 01-02/09, **chưa kiểm chứng lại bằng code**. Story, DoD, demo và tiêu chí nghiệm thu lấy nguyên văn từ docs/analysis/08-roadmap-va-ke-hoach-trien-khai.md §6-§7. Nhóm "Bổ sung từ mockup" là việc mới lộ ra từ bộ mockup web ngày 18-19/09 và quyết định của chủ dự án ngày 19/09.

2. M1 · API nền + Auth — chốt 02/10/2026

Sprint: S1 · Tổng: 49 mục ·  3 ·  8 ·  23 ·  5 ·  8 ·  2 · Tỷ lệ xong: 6%

Mục tiêu:

- S1 — Định danh & Xác thực (21/09 – 02/10/2026): Một người thật tạo được tài khoản, đăng nhập trên cả web lẫn điện thoại, và phiên đăng nhập giữ được qua nhiều ngày mà không tự đăng xuất.

Nếu trượt: M1 không được trượt. Đây là mắt xích đường găng cứng nhất phía kỹ thuật — toàn bộ E3, E4, E6 đều chờ nó. Trượt M1 thì trượt hết. Phương án khẩn: cắt E2-S5 (Facebook) và E2-S6 (đặt lại mật khẩu) sang S2, dồn 2 người vào E2-S2 và E2-S9.

2.1. Việc chặn & cần chốt

☐	Mã	Nội dung	Phụ trách	Trạng thái	Ghi chú / bằng chứng
☐	CH-01	Nghĩa vụ xác thực SĐT Việt Nam theo NĐ 147/2024: mọi tài khoản hay chỉ tài khoản đăng nội dung công khai.	Founder + Luật sư	 Cần chốt	Hạn 21/09. Code đang ngấm chọn "không bắt buộc".
☐	MT-17	Chốt tên guard/decorator trust và RBAC (code: TrustLevelGuard/@MinTrustLevel; doc: TrustTierGuard/@MinTrust).	Tech Lead	 Cần chốt	Hạn 21/09; chặn E2-S7.
☐	MT-16	user_status_enum 5 hay 8 giá trị (enum Postgres không xoá được giá trị).	Tech Lead	 Cần chốt	Hạn 02/10.
☐	PERM-MATRIX	Vị trí PERMISSION_MATRIX máy đọc được (doc 00: packages/shared-types; doc 01: apps/api/.../authz/) + test describe.each T-1→T-5.	Tech Lead	 Cần chốt	Hạn 21/09.
☐	ADR-C9	Có tách schema identity_secret cho bảng xác thực mới không (ADR-0000 mục C9).	Founder	 Cần chốt	Hạn ký 07/09 đã qua.
☐	TOKEN-MOBILE	Một cơ chế trả refresh token dùng chung cho web (cookie), mobile (SecureStore) và social login; đổi hợp đồng packages/contracts.	Tech Lead + Backend	 Cần chốt	Chặn E2-S3, E2-S4, E2-S9. Cổng phê duyệt: đổi packages dùng chung.
☐	BR-30	Nội dung Điều khoản / Chính sách quyền riêng tư và cơ chế consent_records (NĐ 13/2023 + Luật 91/2025).	Founder + Luật sư	 Cần chốt	Cần luật sư xác nhận.
☐	ACC-APPLE-GOOGLE	Xác nhận tài khoản Apple Developer tổ chức / D-U-N-S; tạo Google OAuth client (3 ID: web, iOS, Android).	Founder + Tech Lead	 Chưa xác nhận	—

☐	Mã	Nội dung	Phụ trách	Trạng thái	Ghi chú / bằng chứng
☐	OWNERS	Gán người phụ trách cho T-10, T-11, T-12, T-14 trong ACTIVE_TASKS.	Coordinator	☐ Chưa làm	Cột người phụ trách đang trống.
☐	INFRA-MAIL	Nối mail client (SMTP → Mailpit) dùng chung cho E2-S1 và E2-S6.	Backend	☐ Chưa làm	—
☐	INFRA-REDIS	Nối Redis client (ioredis / BullMQ) cho rate limit E2-S10 và job trust:recompute (T-13).	Backend	☐ Chưa làm	—
☐	SEC-JWT-LOG	Vá lỗi ghi khoá riêng JWT ra log debug khi thiếu JWT_PRIVATE_KEY (auth.service.ts:107), trước khi bật log tập trung.	Backend	☐ Chưa làm	Lỗi bảo mật.
☐	T-14	Dựng Playwright ở apps/web-client-side/e2e/, chạy cả WebKit.	Tester	☐ Chưa làm	Ba bug chỉ-có-ở-client đã lọt lưới.

2.2. Story

☐	Mã	Nội dung	Phụ trách	Trạng thái	Ghi chú / bằng chứng
☐	E2-S1	Đăng ký email + xác minh email (8 SP) · MUST	Backend	☐ Một phần	Đăng ký có nhưng cấp phiên + T1 ngay; chưa có token xác minh, endpoint verify, gửi mail (Mailpit đã chạy).
☒	E2-S2	JWT access 15 phút + refresh 30 ngày xoay vòng, phát hiện tái sử dụng (8 SP) · MUST	Backend	☒ Xong	Access 15 phút + refresh 30 ngày xoay vòng; test e2e "dùng lại token → thu hồi cả họ" (auth.e2e.spec.ts:323).
☐	E2-S3	Đăng nhập Google (5 SP) · MUST	Backend + Mobile	☐ Bị chặn	Chờ khung Expo (E1-S6), bảng social_accounts, endpoint /auth/social, Google OAuth client.
☐	E2-S4	Đăng nhập Apple (Guideline 4.8) (5 SP) · MUST	Mobile + Backend	☐ Bị chặn	Như E2-S3, thêm tài khoản Apple Developer tổ chức / D-U-N-S.
☐	E2-S6	Đặt lại mật khẩu qua email (3 SP) · MUST	Backend	☐ Chưa làm	Chưa có luồng quên / đặt lại mật khẩu.
☐	E2-S7	Enum role toàn cục 5 giá trị + guard RBAC (5 SP) · MUST	Backend	☐ Một phần	Enum 5 role đã đúng; chưa có RolesGuard/@Roles, chỉ có TrustLevelGuard.
☐	E2-S8	Màn đăng nhập/đăng ký web, trạng thái lỗi rõ ràng (5 SP) · MUST	Web	☐ Một phần	Màn đăng nhập/đăng ký web có; thiếu nhánh lỗi 429, locale đang viết cứng "en" (auth-form.tsx:85).
☐	E2-S9	Giữ phiên trên mobile, token trong secure storage (8 SP) · MUST	Mobile	☐ Bị chặn	Refresh token chỉ trả qua cookie httpOnly; phải chốt cơ chế cho mobile trước khi code.
☐	E2-S10	Rate limit endpoint xác thực, chặn dò mật khẩu (3 SP) · MUST	Backend	☐ Chưa làm	Chưa có rate limit; Redis đã chạy trong compose nhưng chưa nối client.
☐	E1-S9	Sentry + log tập trung (3 SP) · MUST	Backend	☐ Chưa làm	Chưa có Sentry / log tập trung.

2.3. DoD bổ sung

☐	Mã	Nội dung	Phụ trách	Trạng thái	Ghi chú / bằng chứng
☐	S1-DoD-1	Migration tạo cột <code>users.role</code> kiểu enum đúng 5 giá trị chữ thường: <code>member</code> , <code>curator</code> , <code>moderator</code> , <code>admin</code> , <code>super_admin</code> . Mặc định <code>member</code> . Không có giá trị <code>guest</code> , <code>organizer</code> , <code>verified_member</code> , <code>support</code> trong enum — kiểm tra bằng một test đọc <code>pg_enum</code> và so khớp đúng 5 phần tử	—	🟡 Một phần	Enum đúng 5 giá trị; chưa có test đọc <code>pg_enum</code> .
☐	S1-DoD-2	Migration tạo cột <code>users.trust_level</code> kiểu <code>smallint</code> , <code>CHECK (trust_level BETWEEN 0 AND 5)</code> , mặc định 0	—	🟡 Một phần	Cột có; đăng ký đang cấp thẳng T1 (<code>TRUST_LEVEL_ON_REGISTER</code>), phải về 0 khi có xác minh email.
☐	S1-DoD-3	Bảng <code>trust_signals</code> đã tạo (append-only), có <code>REVOKE UPDATE</code> , <code>DELETE</code> cho vai trò ứng dụng	—	🟡 Chưa làm	DDL đầy đủ đã có ở doc 03 §4.5, chỉ còn viết migration.
☒	S1-DoD-4	Test e2e luồng tái sử dụng refresh token: dùng lại token đã xoay → toàn bộ họ token của thiết bị đó bị thu hồi, trả 401	—	✅ Xong	<code>auth.e2e.spec.ts:323</code> .
☐	S1-DoD-5	Test guard: <code>member</code> gọi endpoint chỉ dành cho <code>moderator</code> → 403, không phải 404 và không phải 500	—	🟡 Chưa làm	Chưa có <code>RolesGuard</code> .
☐	S1-DoD-6	Đăng nhập Apple chạy thật trên thiết bị iOS thật, không phải simulator	—	🛑 Bị chặn	Chờ khung Expo + tài khoản Apple Developer.
☐	S1-DoD-7	Rate limit: 10 lần đăng nhập sai/IP/15 phút → 429 có header <code>Retry-After</code>	—	🟡 Chưa làm	—
☐	S1-DoD-8	Số đăng ký xử lý dữ liệu cá nhân đã có 3 dòng đầu: email, mật khẩu băm, định danh nhà cung cấp social	—	🟡 Chưa làm	Phụ thuộc DoD S0 số đăng ký.

2.4. Nghiệm thu

☐	Mã	Nội dung	Phụ trách	Trạng thái	Ghi chú / bằng chứng
☐	M1-1	Đăng ký + xác minh email chạy end-to-end trên web và mobile	—	🟡 Một phần	Web có đăng ký nhưng chưa có xác minh email; mobile chưa có. Bằng chứng: Video 2 nền tảng
☐	M1-2	Đăng nhập Google và Apple chạy trên thiết bị thật, không phải simulator	—	🛑 Bị chặn	Bằng chứng: Video thiết bị
☒	M1-3	Refresh token rotation có test e2e, gồm ca tái sử dụng token đã xoay → thu hồi cả họ	—	✅ Xong	Bằng chứng: Báo cáo test

☐	Mã	Nội dung	Phụ trách	Trạng thái	Ghi chú / bằng chứng
☐	M1-4	users.role là enum đúng 5 giá trị member/curator/moderator/admin/super_admin; không có guest, organizer, verified_member, support	—	🟡 Một phần	Thiếu test pg_enum. Bằng chứng: Test đọc pg_enum
☐	M1-5	Guard RBAC chặn đúng: member gọi endpoint moderator → 403	—	🟡 Chưa làm	Bằng chứng: Test e2e
☐	M1-6	users.trust_level smallint 0-5 đã có, mặc định 0; bảng trust_signals append-only đã có	—	🟡 Một phần	trust_signals chưa có. Bằng chứng: Migration + kiểm tra quyền
☐	M1-7	Rate limit endpoint xác thực hoạt động, trả 429 có Retry-After	—	🟡 Chưa làm	Bằng chứng: Kịch bản test
☐	M1-8	Sổ đăng ký hoạt động xử lý dữ liệu cá nhân đã mở, có ≥ 3 mục	—	🟡 Chưa làm	Bằng chứng: File sổ đăng ký

2.5. Demo

☐	Mã	Nội dung	Phụ trách	Trạng thái	Ghi chú / bằng chứng
☐	S1-Demo-1	Trên web: đăng ký bằng email thật → nhận mail xác minh → bấm xác minh → vào được khu vực đã đăng nhập	—	🟡 Chưa làm	—
☐	S1-Demo-2	Trên iPhone thật: đăng nhập bằng Apple ID → đóng app hoàn toàn → mở lại sau 10 phút → vẫn đăng nhập	—	🟡 Chưa làm	—
☐	S1-Demo-3	Trên Android thật: đăng nhập Google một chạm	—	🟡 Chưa làm	—
☐	S1-Demo-4	Demo bảo mật: lấy refresh token cũ trong Postman gọi lại → cả họ token bị thu hồi, thiết bị bị đá ra	—	🟡 Chưa làm	—
☐	S1-Demo-5	Demo RBAC: đổi role của tài khoản demo trong DB từ member sang moderator → endpoint kiểm duyệt mở ra ngay lần gọi kế tiếp	—	🟡 Chưa làm	—

2.6. Việc ngoài SP

☐	Mã	Nội dung	Phụ trách	Trạng thái	Ghi chú / bằng chứng
☐	S1-Ops-0	theo dõi hồ sơ D-U-N-S; nếu quá 14 ngày chưa có kết quả thì mở ticket với Dun & Bradstreet — đây là ngưỡng cảnh báo đường găng đầu tiên.	Founder / Community Manager	🟡 Chưa xác nhận	—

2.7. Bổ sung từ mockup

☐	Mã	Nội dung	Phụ trách	Trạng thái	Ghi chú / bằng chứng
☐	MK-AUTH-01	Chốt form đăng ký theo UC-01: 3 trường, mật khẩu ≥ 10 ký tự + 4 điều kiện, 2 ô đồng ý tách riêng không tích sẵn, không báo "email đã tồn tại". Code hiện có trường handle, mật khẩu ≥ 12, trả EMAIL_TAKEN.	BA	? Cần chốt	—
☐	MK-AUTH-02	Màn "Check your inbox": mã 6 số, gửi lại sau 60 giây (tối đa 5 lần / 24 giờ), đổi email 1 lần, khoá 15 phút sau 5 lần sai; trang link thành công / hết hạn / đã dùng / mở trên máy khác.	Web + Backend	Chưa làm	—
☐	MK-AUTH-03	Đặt lại mật khẩu: màn gửi mail trung tính (không lộ email), đăng xuất mọi phiên khác sau khi đổi.	Web + Backend	Chưa làm	—
☐	MK-AUTH-04	Social login: màn "email này đã có tài khoản — đăng nhập để liên kết", không tự hợp nhất.	Web + Mobile + Backend	Chưa làm	—